

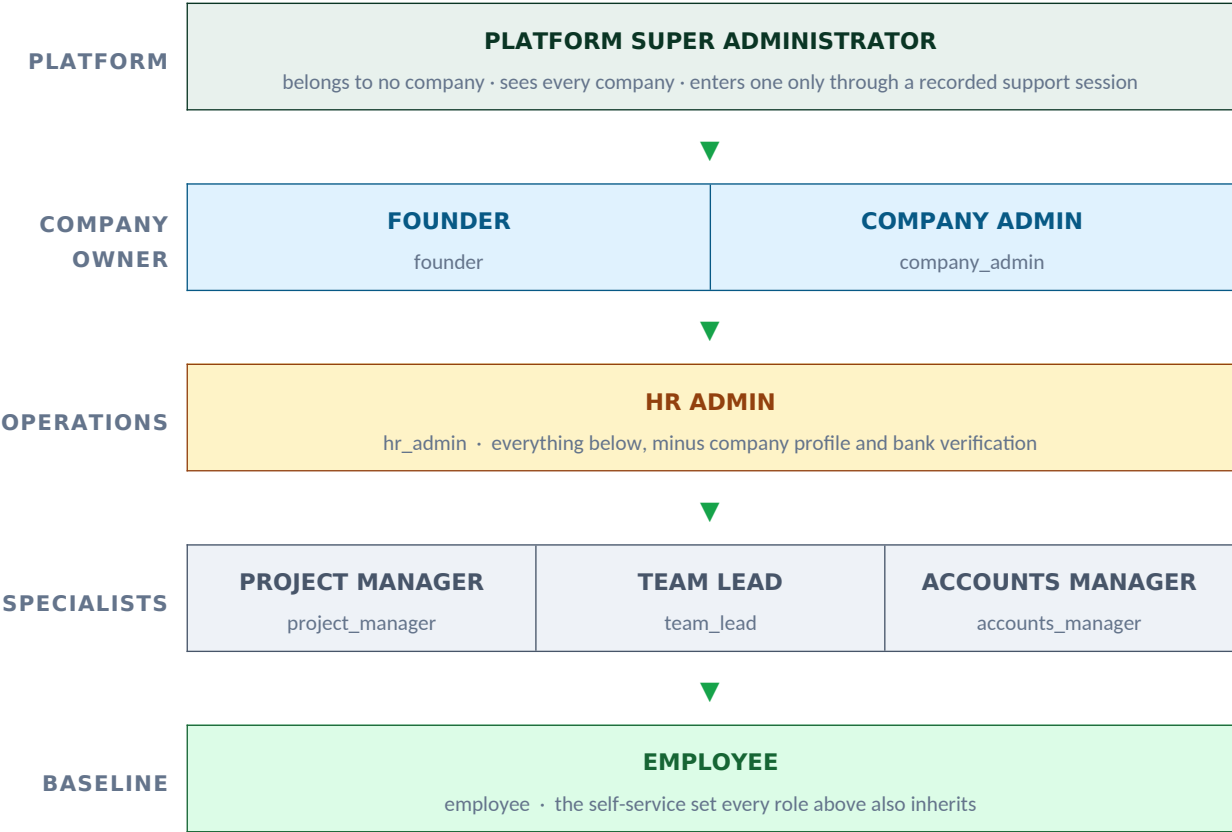


Role Hierarchy & Access Control

HRMS Mobile Application · reference sheet for documentation and RBAC design

Whhoooh Path LLP · Multi-tenant · Version 1.0 · 10 September 2026

1 The Hierarchy



2 Three Things That Break The Straight Line

The diagram reads top to bottom, but it is not a simple ladder, and the exceptions are the parts worth designing against.

Where it breaks	What is actually true	Consequence for the design
Founder = Company Admin	Not a parent and a child. Every rule that names one names the other, so the two are one privilege level with two labels.	Any check written for founder must accept company_admin. A single helper, not two branches.
Accounts is not below HR	It holds a right HR does not: verifying the payout bank account. HR may enter an account; only Founder, Company Admin or Accounts Manager may approve it.	Separation of duties. Bank edit and bank verify are two distinct permissions, never one.

Where it breaks	What is actually true	Consequence for the design
The specialists are siblings	Project Manager, Team Lead and Accounts Manager each branch off Employee. A Project Manager has no more reach over people than any employee.	Not a linear rank. Model capability sets per role, not an ordered level number.

3 A Second, Separate Hierarchy

The reporting line is not the role hierarchy and must not be modelled as one. It is a self-referencing field on the employee record, and it forms the org chart.

	Role hierarchy	Reporting hierarchy
What it decides	What a person may open and do.	Who a person answers to.
Where it lives	One role value on the user record.	A reporting-manager reference on the employee record.
Set at	Employees → Edit → Role	Employees → Edit → Reporting manager
Read back at	Settings → Roles & Permissions	Reports → Reporting Manager (flags anyone unassigned)
Independent?	Entirely. A Team Lead may report to an HR Admin; an Employee may report to the Founder.	

4 Capability Matrix

Written against the internal role identifiers, so it can be used as a specification rather than a description.

FND	founder	CADM	company_admin	HR	hr_admin	PM	project_manager
TL	team_lead	EMP	employee	ACC	accounts_manager		• full • own = own records only • view = read without change • • = denied

Capability	FND	CADM	HR	PM	TL	EMP	ACC
employees.view	•	•	•	view	view	view	view
employees.manage	•	•	•	•	•	•	•
employees.sensitive – PAN, Aadhaar, bank	•	•	•	•	•	own	•
attendance.own	•	•	•	•	•	•	•
attendance.company	•	•	•	•	•	•	•
leave.apply	•	•	•	•	•	•	•
leave.decide	•	•	•	•	•	•	•
payroll.read	•	•	•	own	own	own	•
payroll.manage – run, structures	•	•	•	•	•	•	•
bank.view	•	•	•	•	•	•	•
bank.edit	•	•	•	•	•	•	•
bank.verify	•	•	•	•	•	•	•
letters.read	•	•	•	own	own	own	own
letters.issue	•	•	•	•	•	•	•
policies.manage	•	•	•	•	•	•	•
projects.manage	•	•	•	•	•	•	•
tasks.manage – create, reassign, re-scope	•	•	•	•	•	•	•
tasks.progress – report own %	•	•	•	•	•	•	•
assets.manage	•	•	•	•	•	•	•
recruitment.manage	•	•	•	•	•	•	•

Capability	FND	CADM	HR	PM	TL	EMP	ACC
calendar.create	•	•	•	•	•	•	•
announcements.manage	•	•	•	•	•	•	•
reports.read	•	•	•	•	•	•	•
settings.org – depts, designations, SMTP, audit	•	•	•	•	•	•	•
settings.company_profile	•	•	•	•	•	•	•
messages	•	•	•	•	•	•	•
platform.console	•	•	•	•	•	•	•

platform.console belongs to the platform super administrator, who sits outside every company and holds no company role at all.

5 Where Each Rule Is Enforced

Layer	Mechanism	What it decides	Worth knowing
Navigation	Route guards and module-tile filters	Which screens and tiles a role is offered.	Courtesy only. Hiding a control grants nothing and protects nothing.
Row visibility	Row-level security on every table	Which rows a read returns — own records, or the whole company.	Invisible for the roles that see least, so a missing filter shows up only for HR. Scope queries explicitly where the screen is personal.
Column visibility	Column grants	PAN, Aadhaar and bank cannot be read from the employee table at any role.	A dedicated function is the only route, and it returns them to HR-level roles and to the employee themselves.
Operation	Security-definer functions	Whether the write or the aggregate happens at all.	Each re-checks the caller: the leave balance, who may decide, whether the caller holds an HR role before a report reads a row.

ONE GAP TO CLOSE BEFORE THIS IS USED AS AN RBAC SPECIFICATION

The Role dropdown on the employee form offers five of the seven company roles: Founder, HR Admin, Project Manager, Team Lead and Employee.

company_admin and accounts_manager exist in the role type and are honoured by every rule in the database — but they cannot be assigned from the interface. Today they have to be set directly against the record.

Either add the two options to that dropdown, or document them as provisioning-time roles that the platform administrator sets during company setup. Leaving it unstated is what will cause a support call.